

CSIT302 Cybersecurity

Day 5-2 – Threat Intelligence & Investigating Incident

Subject Coordinators: Dr Partha Sarathi Roy
School of Computing and Information Technology

Overview: Threat Intelligence

- Introduction to threat intelligence
- Open-source tools for threat intelligence
- Microsoft threat intelligence
- Leveraging threat intelligence to investigate suspicious activity

Intelligence

Data vs information vs intelligence

The terms data, information and intelligence are often incorrectly used interchangeably.

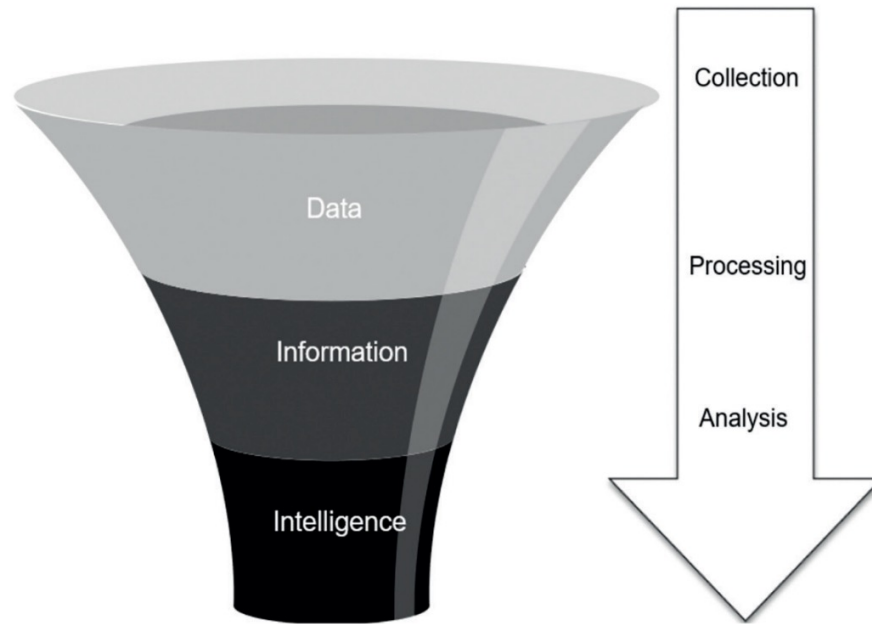


Figure 2: Producing intelligence from raw data

Data refers to simple facts that tend to be available in large volumes. In the context of cyber security, IP addresses or logs are typical examples. By itself, raw data is of limited utility.

Information is produced when this data is collated to provide a useful output – for example, a collated series of logs showing a spike in suspicious activity.

Intelligence comes from the processing and analysis of this information and can be used to inform decision making. For example, the collated log data is contextualised with prior incident reports regarding similar activity, which also allows for the development of a strategy to mitigate the incident.

<https://www.crest-approved.org/wp-content/uploads/2022/04/CREST-Cyber-Threat-Intelligence.pdf>



Introduction to Threat Intelligence

- Threat intelligence
 - “Intelligence is knowledge and foreknowledge of the world around us – the prelude to decision and action...” - US Central Intelligence Agency (CIA)
 - “Intelligence is information that is received or collected to answer specific questions on who, what, where, when, how and why...” - UK National Crime Agency (NCA)
 - “Threat intelligence is threat information that has been aggregated, transformed, analysed, interpreted, or enriched to provide the necessary context for decision-making processes.” - NIST SP 800-150
 - Intelligence Collection Disciplines: OSINT, HUMINT, SIGINT, GEOINT and IMINT
- Threat intelligence in other context
 - The term “threat intelligence” from military, which are mainly based on HUMINT and SIGINT.
 - In the context of cybersecurity as well as our subject, **threat intelligence refers to Cyber Threat Intelligence.**

Introduction to Threat Intelligence

- Cyber threat intelligence
 - Using threat intelligence towards the collected data can bring more meaningful results and reveal actions that are not detectable by traditional sensors.
 - This enables an organization to take proactive approach against known and unknown threat. → The targeted attacks need the targeted defense!
- The areas where the information obtained from (cyber) threat intelligence can be used:
 - Profiling motivations: cybercrime, hactivism, cyber espionage (more on next page)
 - Analyzing attacker tactics: attacker methodologies, tools and strategy
 - Analyzing techniques (of attacks): indicators of specific malware
 - Assessing operations: assessment of an organisation's ability in determining future cyber-threats

Introduction to Threat Intelligence

- **Examples of profiling motivation:** Detection can be improved by learning more about the adversaries
 - **Cybercrime:** One of the main motivations is to obtain financial gains.
 - **Hacktivism:** This group has a broader scope of motivation—it can range from an expression of political preference to just an expression for a particular cause.
 - **Cyber espionage/state-sponsored:** There are a growing number of cyber espionage cases as a part of bigger state-sponsored campaigns.
- The question to ask: Which type of attacker among three is most likely to target our organization?
- Threat Intelligence could help scope data based on the adversary.
 - For example, if we are responsible for the defense of a financial institution, we want to obtain threat intelligence from adversaries that are actively attacking the financial industry.

Introduction to Threat Intelligence

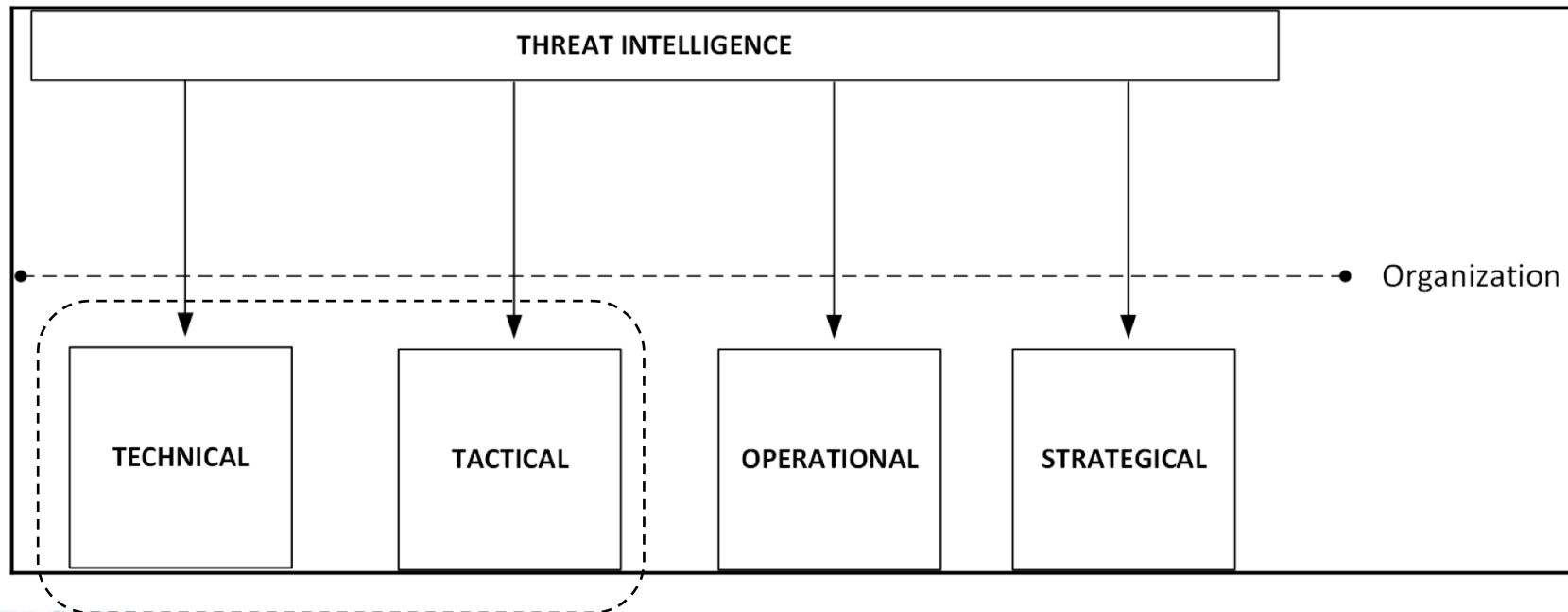
- Scoping the adversary
 - Using an *intelligence-led approach* has long been accepted as best practice in the realm of conventional security.
 - Without it, organisations will invariably defend against **too little**, because they don't understand the threats they face, or **try to defend against all potential** threats – an unsustainable approach that may also impair the organization's ability to operate effectively.
- The cyber threat intelligence ensures that organizations have their ability to prevent, detect and respond to realistic, contemporary and accurate attacks.

Introduction to Threat Intelligence

- The Bank of England's CBEST was the first intelligence-led cyber security testing frameworks, which ensures that organizations are tested on their ability of cyber threat intelligence.
- The CBEST framework ensures that security testers and threat intelligence providers work together, replicating very real attacks from sophisticated adversaries.
- The principle has since expanded, both internationally to other financial sectors. These schemes include:
 - TIBER-NL (Threat Intelligence Based Ethical Red-teaming Netherlands) for the Dutch financial sector
 - TBEST for the UK telecoms sector
 - TIBER-EU for the European financial sector
 - iCAST (Intelligence-led Cyber Attack Simulation Testing) for Hong Kong's financial sector
 - GBEST for UK government departments
 - ATTEST for the UK aviation industry

The levels of cyber threat intelligence

- There are different areas that cyber threat intelligence can be used: Each area differs in the nature and format of the material conveyed, its intended audience and its application.



The levels of cyber threat intelligence

- Operational threat intelligence:

- operational threat intelligence uses the collection of data and information to respond to a threat or attack as it is in progress. It is meant to be used immediately and provides real-time alerts that can help your security team understand the scope of an attack and defend against it. It is a critical part of detecting active threats and responding to them quickly, so that your organization suffers minimal harm
- Operational threat intelligence often relates to details of potential impending operations against an organisation. Although it is not always easy to obtain, by using an all-source approach an intelligence provider will be able to detect.
- e.g., chatter from cyber activists discussing potential targets for an upcoming campaign, or data leaked or sold on a dark web forum that could be used in an operation against the company.

The levels of cyber threat intelligence

- Tactical threat intelligence:
 - It consists of material relating to the ***techniques, tactics and procedures (TTP's)*** used by threat actors. Indicators of compromise (IOCs) are the main deliverable for tactical threat intelligence providers.
 - These are particularly useful for updating signature-based defence systems to defend against known attack types, but can also prove useful for more proactive measures, such as threat hunting exercises.
 - It is therefore particularly useful to network defenders such as Network Operations Centers (NOCs). CTI (Cyber Threat Intelligence) providers will generally supply IOCs in machine-readable formats, whereas intelligence on TTPs will be in human-readable formats and will require human assimilation and action.
- Strategic threat intelligence
 - exists to inform senior decision makers of broader changes in the threat landscape.

The Levels of Cyber Threat Intelligence

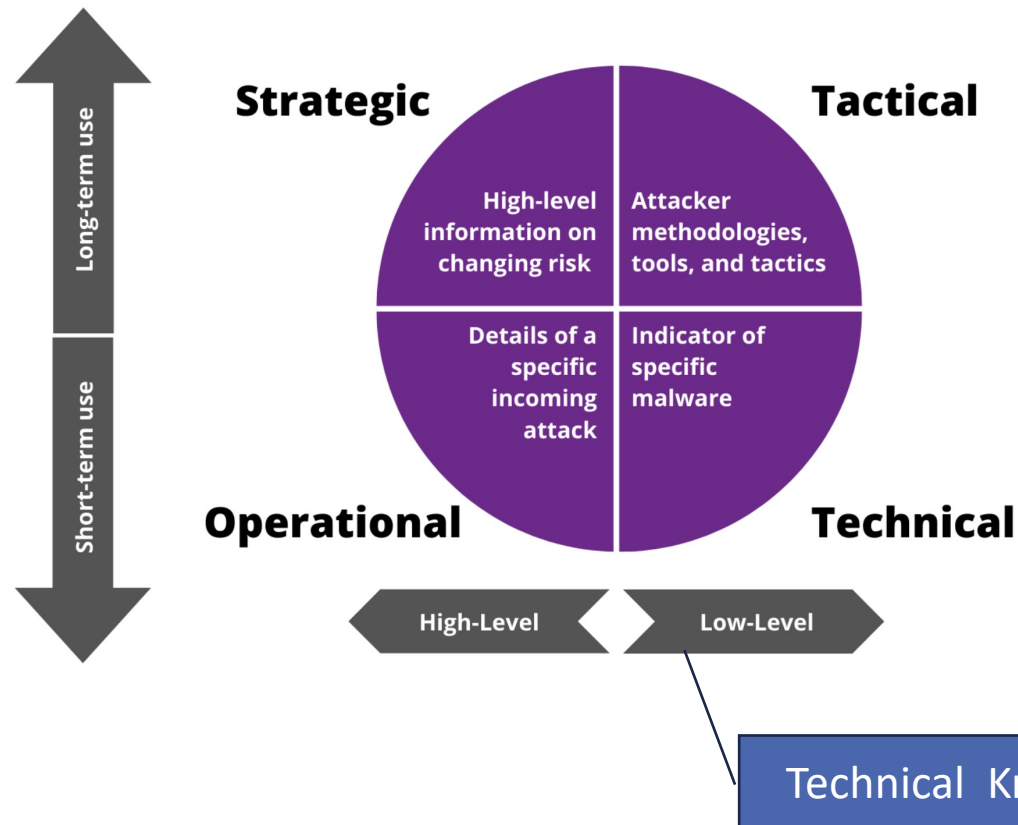


Figure 5: The three levels of cyber threat intelligence

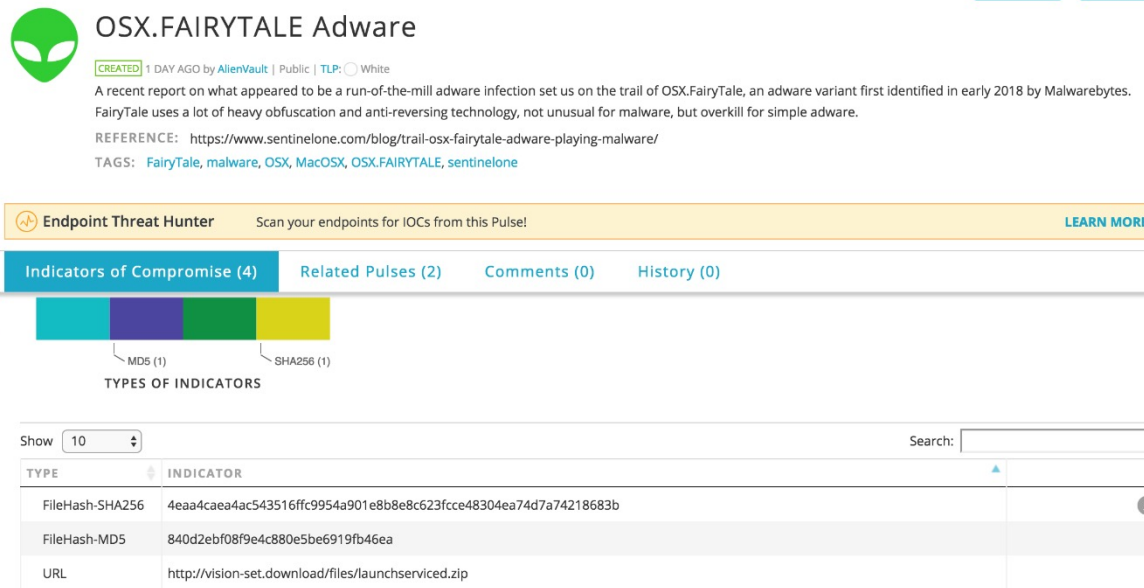


Microsoft Threat Intelligence

- For example, Microsoft consumes threat intelligence through different channels, such as:
 - The Microsoft Threat Intelligence Center, which aggregates data from:
 - ✓ Honeypots, malicious IP addresses, botnets, and malware detonation feeds
 - ✓ Third-party sources (threat intelligence feeds)
 - ✓ Human-based observation and intelligence collection
 - Intelligence coming from consumption of their service
 - Intelligence feeds generated by Microsoft and third parties

Open Source Tools for Threat Intelligence

- Various open source tools (for tactical threat Intelligences):
 - Quick IP validation: <https://fraudguard.io/>
 - Malware inspection: <https://vms.drweb.com/> (Note that malwr.com in the textbook is not available.)
 - Threat intelligence exchange: <https://otx.alienvault.com/>



OSX.FAIRYTALE Adware

CREATED 1 DAY AGO by AlienVault | Public | TLP: White

A recent report on what appeared to be a run-of-the-mill adware infection set us on the trail of OSX.FairyTale, an adware variant first identified in early 2018 by Malwarebytes. FairyTale uses a lot of heavy obfuscation and anti-reversing technology, not unusual for malware, but overkill for simple adware.

REFERENCE: <https://www.sentinelone.com/blog/trail-osx-fairytale-adware-playing-malware/>

TAGS: FairyTale, malware, OSX, MacOSX, OSX.FAIRYTALE, sentinelone

Endpoint Threat Hunter Scan your endpoints for IOCs from this Pulse! [LEARN MORE](#)

Indicators of Compromise (4) Related Pulses (2) Comments (0) History (0)

TYPES OF INDICATORS

TYPE	INDICATOR
FileHash-SHA256	4eaa4caea4ac543516ffc9954a901e8b8e8c623fcca48304ea74d7a74218683b
FileHash-MD5	840d2ebf08f9e4c880e5be6919fb46ea
URL	http://vision-set.download/files/launchserviced.zip

Quick IP Validation

- For instance, test IP “220.227.71.226” on 10/27/2017, the result was

```
{  
  "isocode": "IN",  
  "country": "India",  
  "state": "Maharashtra",  
  "city": "Mumbai",  
  "discover_date": "2017-10-27 09:32:45",  
  "threat": "honeypot_tracker",  
  "risk_level": "5"  
}
```

Leveraging Threat Intelligence to Investigate Suspicious Activity

- Challenges of interpreting many security alerts
 - According to Microsoft's *Lean on the Machine* report, an average large organization has to look through 17,000 malware alerts each week, taking on average 99 days for an organization to discover a security breach.
 - End up randomly prioritizing, and in some cases even ignoring, future alerts.
- Threat intelligence assisting incident response
 - The Blue Team works primarily on the defense system, they do collaborate with the incident response team by providing the right data that can lead them to find the root cause of the issue.

Leveraging Threat Intelligence to Investigate Suspicious Activity

- Alert triage
 - The process of determining the most important threat that must be alerted.
 - Failing/delaying this process can lead to a domino effect, because if triage fails at this level, the operation will also fail.
- The alert triage usually happens at Network Operations Center (NOC).
Questions at the end of threat intelligence
 - Which systems were compromised?
 - Where did the attack start?
 - Which user account was used to start the attack?
 - Did it move laterally?
 - ✓ If it did, what were the systems involved in this movement?

Leveraging Threat Intelligence to Investigate Suspicious Activity

- Did it escalate privilege?
 - ✓ If it did, which privilege account was compromised?
- Did it try to communicate with command and control?
 - ✓ If it did, was it successful?
 - If it was, did it download anything from there?
 - If it was, did it send anything to there?
- Did it try to clear evidence?
 - ✓ If it did, was it successful?

[Additional Reference in Threat Intelligence section]

[What is Cyber Threat Intelligence and how is it used? – CREST, 2022](#)

Overview: Investigating an Incident

- Scoping the issue
- On-premises compromised system
- Cloud-based compromised system
- Lessons learned

Scoping the Issue

- **Scoping** in the incident investigation
 - A process to determine a given incident is security-related.
- Reasons for scoping
 - Not every incident is a security-related incident, and, for this reason, it is vital to scope the issue prior to start an investigation.
 - Sometimes, the symptoms may lead the investigator to initially think they are security-related, but as the investigator ask more questions and collect more data, it turns out that the problem was not really related to security.

Scoping the Issue

- Scoping example
 - Users reporting systems running “slow”: Rather than dispatching a security responder to initiate an investigation, basic performance troubleshooting should be conducted.
 - During this initial scoping stage, it is also important to determine the frequency of the issue. - If the issue is not currently happening, the investigator may need to configure the environment to collect data when the user is able to reproduce the problem.
 - Make sure to document all the steps and provide an accurate action plan for the end use.

Key Artifacts

- More data doesn't necessarily mean better investigation.
- Data collection should focus on obtaining just the *vital* and *relevant* artifacts from the target system.
 - Too much data can deviate security team from the root cause of the problem.
- It is important to make sure you know the information of your system
- In a Windows system, the information is usually located in the registry key.
- It can be retrieved by PowerShell command (e.g., `Get-ItemProperty`) .

Key Artifacts

- Key artifacts in Windows system
 - The location (time zone) of the machine
 - The networks the machine visited
 - USB usage
 - If there is any malicious software configured to start when Windows starts
- In addition, traffics and processes dumps can be collected, if this is live investigation.

Key Artifacts

- All security events can be captured :
 - The audit log was cleared.
 - Logging-on success or failure.
 - A registry value was modified.
 - An attempt was made to access an object (e.g. unauthorized access to the file system): This log can be used to drill down who performed this change.
 - A new process has been created: The malware and ransomware have a `cmd.exe [command]`. This will create a new process.
 - A scheduled task was enabled or updated.

Key Artifacts

- All security events can be captured :
 - The user account
 - ✓ enabled, created, or locked-out account.
 - ✓ password reset.
 - ✓ denied remote access.
 - Policies
 - ✓ Log policy changed.
 - ✓ Domain policy changed.
 - ✓ Changes in security-enabled global (or local) group.
 - A change has been made to Windows Firewall exception list.

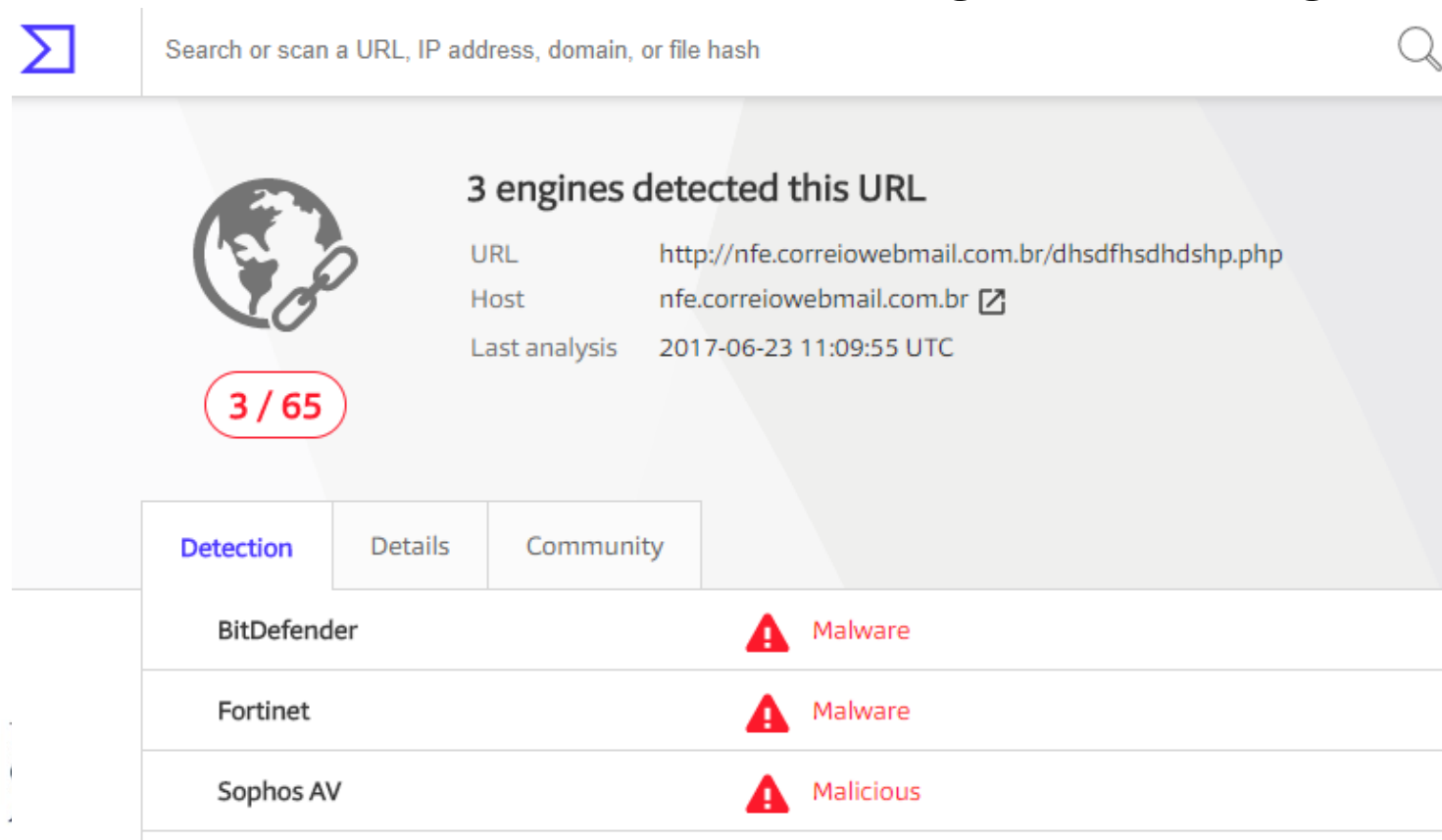
Investigating a Compromised System On-Premises

- Compromised by phishing email
 - The end user (victim) was received the content of the email, which triggered the victim to click the image in the email.
 - The victim tried to download it but couldn't and only had a glimpse of a quickly opening and disappearing window.
 - Then, the victim ignored the email.
- Detection
 - A couple of days later, he receiving an automated report from IT saying that he accessed a suspicious site and he should call support to follow up on this ticket.
 - The victim submitted the suspicious mail as an evidence.

Investigating a Compromised System On-Premises

- Investigation steps

➤ The URL which was linked in the image was investigated.



The screenshot shows a search interface for a URL. The search bar contains the text "Search or scan a URL, IP address, domain, or file hash". Below the search bar, the results show "3 engines detected this URL". The URL is "http://nfe.correiowebmail.com.br/dhsdfhsdhdshp.php", the host is "nfe.correiowebmail.com.br", and the last analysis was on "2017-06-23 11:09:55 UTC". A red circle with "3 / 65" is visible. Below the search results, there are three tabs: "Detection", "Details", and "Community". The "Detection" tab is active, showing a table of detection results from three engines: BitDefender, Fortinet, and Sophos AV. All three engines detected the URL as malicious.

Engine	Detection
BitDefender	Malware
Fortinet	Malware
Sophos AV	Malicious

This was already a strong indication that this site was malicious .



Investigating a Compromised System On-Premises

➤ The next step is to review the event logs. The meaningful logs are:

Process Information:

New Process ID: 0x1da8
New Process Name: C:\tempTools\mimix64\mimikatz.exe
Token Elevation Type: %%1937
Mandatory Label: Mandatory LabelHigh Mandatory Level
Creator Process ID: 0xd88
Creator Process Name: C:\Windows\System32\cmd.exe
Process Command Line:

mimikatz: Used to perform pass-the-hash attack

Process Information:

New Process ID: 0x510
New Process Name: C:\tempTools\PSEXEC\PSEXEC.exe

PSEXEC: Used to perform privileges escalation

Process Information:

New Process ID: 0xc70
New Process Name: C:\tempTools\ProcDump\procdump.exe

procdump: Used to dump the credentials

Investigating a Compromised System On-Premises

➤ The meaningful logs are:

```
Log Name:      Security
Source:        Microsoft-Windows-Eventlog
Event ID:      1102
Task Category: Log clear
Level:         Information
Keywords:      Audit Success
User:          N/A
Computer:      BRANCHBR
Description:
The audit log was cleared.
Subject:
  Security ID:  BRANCHBRJose
  Account Name: BRANCHBR
  Domain Name:  BRANCHBR
  Logon ID:     0x3D3214
```

← The attacker cleared logs. It hid how the attacker achieved privilege escalation.

Investigating a Compromised System On-Premises

- Summary of the case
 - Everything started with a phishing email.
 - This email had an embedded image that had a hyperlink to a site that was compromised.
 - A package was downloaded and extracted in the local system, this package contained many tools, such as `mimikatz`, `procdump`, and `psexec`.
 - This computer was not part of the domain, so only local credentials were compromised.

Investigating a Compromised System In a Hybrid Cloud

- Compromised by phishing email – Cloud version
 - In this hybrid scenario, the compromised system is located on-premises and the company has a cloud-based monitoring system.
 - Again, a user received a phishing email, clicked on the hyperlink, and got compromised.
 - The difference now is that there is **an active sensor monitoring the system**, which will trigger an alert to SecOps, and the user will be contacted. The users don't need to wait days to realize they were compromised; the response is faster and more accurate.
 - The example of the active sensor is Azure Security Center and four events were recorded.

Investigating a Compromised System In a Hybrid Cloud

DESCRIPTION	COUNT	DETECTION TIME	ATTACKED RESOURCE	SEVERITY
 Antimalware Action Taken	4	11/14/17 04:29 PM	MVAVMONPrem	 Low
 Suspicious process name detected	2	11/15/17 12:21 PM	MVAVMONPrem	 Medium
 Suspicious Process Execution Activity Detected	1	11/15/17 12:21 PM	MVAVMONPrem	 Medium
 Suspicious process executed	3	11/15/17 12:21 PM	MVAVMONPrem	 High

- Although the antimalware software captured the malware, the attacker kept going and succeeded as the last three events show.
- The last three events are related to the serious mimikatz process.

Investigating a Compromised System In a Hybrid Cloud

➤ The following figure shows the mimikatz process, which was executed.

Suspicious process executed
MVAVMONPREM

Investigate

Run playbooks

DESCRIPTION

Machine logs indicate that the suspicious Process: 'c:\temp\tools\mimi\x64\mimikatz.exe' was running on the machine.

DETECTION TIME

Wednesday, November 15, 2017 12:21:12 PM

SEVERITY

High

STATE

Active

ATTACKED RESOURCE

MVAVMONPREM

DOMAIN NAME	MVAVMONPREM
PARENT PROCESS	cmd.exe
PARENT PROCESS ID	3464
PROCESS ID	5212
USER NAME	EMSAdmin
USER SID	S-1-5-21-3530110996-1287965346-2161999582-1001
REPORTS	Report: Hacker tool executed

mimikatz should be run under high profile (admin) account

Search and you shall find it

- In a real-world scenario, the amount of data that gets collected by sensors and monitoring systems can be overwhelming.
 - A security monitoring system that can aggregate all these logs, digest them, and rationalize the result.
 - You also need searching capabilities to be able to keep digging up more important information.
 - It is important to be used to those search capability of the platform that you are using and familiar with commands to further analysis.
 - Also, the platform should provide efficient visualizing and searching interfaces.

Lessons Learned

- Every time an incident comes to its closure,
 - Each step that was done during the investigation should be documented.
 - Key aspects of the investigation that need to be either reviewed to improve or fix should be identified.
- The lessons learned are crucial for the continuous improvement of the process and to avoid making the same mistakes again.
- the Blue Team should create an extensive report to document the lessons learned and how this will be used to improve the defense controls.

Lessons Learned

- Lessons learned from the examples: Attacks against a user's credential are a growing threat and the solution is not based on a silver bullet product, instead, it is a combination of tasks, such as:
 - Reducing the number of administrative level accounts and eliminating administrative accounts in local computers. (Regular users shouldn't be administrators on their own workstation.)
 - Using multifactor authentication as much as possible. Adjusting the organization's security policies to restrict login rights.
 - Having a plan to periodically reset the **Kerberos TGT (KRBGTGT)** account. This account is used to perform a golden ticket attack.